CIS 4401: Information Systems Audit

Course Outline

CIS 4401: Information Systems Audit

Contact Hours: 45 hours

Prerequisites: CIT 4303 IT Security and Risk Management

Purpose: This unit of study aims to review concepts, theory, methodologies and techniques in the Information Systems (IS) Audit profession.

Expected Learning Outcomes

At the end of this course the student should be able to:

i. Explain and apply the concepts and theory underlying IS Auditing;
ii. Describe IS Auditing practice considering techniques and methods for auditing computerized information systems;
iii. Design, construct and run audit software to analyze information held on auditee computer files;
iv. Review and assess the current status of professional and legal requirements; and
v. Discuss current research issues in IS auditing by use of the web to review current research efforts in IS auditing.

Course Content

IS Audit Overview: Standards and Guidelines (ISACA). IS Audit Management and IS Management. Information Technology Centre Audit – IS Security, DRP and physical security.

IS Development, Quality Assurance and applications. Enterprise Resource Planning, Risk and Control Issues. IS Audit Methodology - planning, risk assessment and testing, reporting and client feedback. The Auditor, The Internet and e-Commerce, IT Fraud. IT Governance and the Auditor. e-Crime and e-Forensics. Legal and Ethical Issues. Future IS Audit Technologies. IS Audit Research.

Mode of Delivery

Lectures, tutorials.

Instructional Materials /Equipment

A computer laboratory, lecture notes, illustration charts, journals, overhead presentation equipment.

Assessment

Type	Weighting (%)
Examination	70%
Continuous Assessment	30%
Total	100%

Core Text Books

i. Nyirongo, A. (2015). *Auditing information systems: enhancing performance of the enterprise* (1st ed.). USA: Trafford Publishing. ISBN: 1490754997.
ii. Hingarh, Veena, Ahmed, & Arif. (2013). *Understanding and Conducting Information Systems Auditing*. West Sussex, UK: John Wiley & Sons. ISBN: 1118343743.
iii. Pompon, R. (2016). *IT security risk control management: an audit preparation plan* (1st ed.). Berkeley, CA: Apress. ISBN: 1484221400.

Core Journals

i. *International Journal of Auditing Technology. ISSN: 1757-8752.*
ii. *Journal of Information Systems and Technology Management. ISSN: 1807-1775.*
iii. *Journal of Management Information Systems. ISSN: 0742-1222.*

Recommended Textbooks

i. Cascarino, R. (2012). *Auditor's guide to IT auditing* (2nd ed.). Hoboken, NJ: John Wiley & Sons Inc. ISBN: 1118147618.
ii. Cannon, D. L., O'Hara, B. T., & Keele, A. (2016). *CISA - Certified Information Systems Auditor: study guide* (4th ed.). Indianapolis, IN: John Wiley & Sons. ISBN: 1119056241.
iii. Gregory, P. H. (2016). *CISA certified information systems auditor all-in-one exam guide* (4th ed.). San Francisco. CA: McGraw-Hill Education. ISBN: 125958416X.

Recommended Journals

i. *Managerial Auditing Journal. ISSN: 0268-6902.*

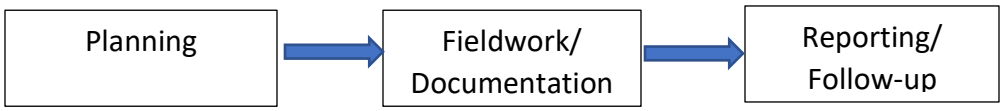
ii. *Journal of Information Technology Management. ISSN: 1042-1319.*

iii. *Journal of Information Assurance & Cybersecurity. ISSN: 2165-9923.*

INFORMATION SYSTEMS AUDIT PROCESS

The audit process requires the IS auditor to gather evidence, evaluate the strengths and weaknesses of internal controls based on the evidence gathered through audit tests, and prepare an audit report that presents weaknesses and recommendations for remediation in an objective manner to stakeholders.

In general terms, the typical audit process consists of three major phases: planning, fieldwork and reporting, as shown below. Enterprises can choose to break down the main phases into multiple phases; for example, the reporting phase can be broken down into three phases: report writing and issuance, issue follow-up, and audit closing. The organization and naming convention can be customized as long as the procedures and outcomes comply with applicable audit standards like those established by ISACA or ISO



Audit Process Phases

The IS auditor must be familiar with standard frameworks and the audit process used by the entity under review in order to use the correct terminology and work organization.

ISO 27001, Information Technology Auditing Framework (ITAF) by ISACA (Information Systems Audit and Control Association is one of the standards that:

- Establishes standards that address IS audit and assurance professional roles and responsibilities; knowledge and skills; and diligence, conduct and reporting requirements
- Defines terms and concepts specific to IS assurance
- Provides guidance and tools and techniques on the planning, design, conduct and reporting of IS audit and assurance assignments
- Outlines several critical hypotheses that are inherent in any IS audit or assurance assignment, including:

  – The subject matter is identifiable and subject to audit.

  – There is a high probability of successful completion of the project.

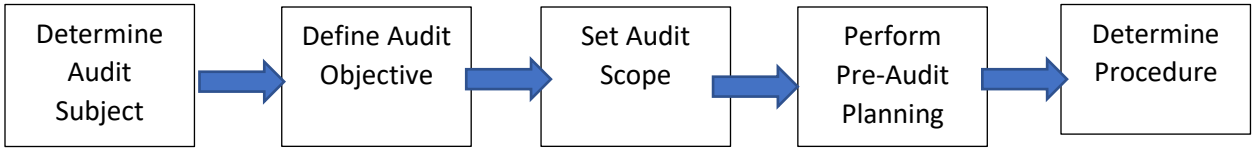
  – The approach and methodology are free from bias.

– The project is of sufficient scope to meet the IS audit or assurance objectives.

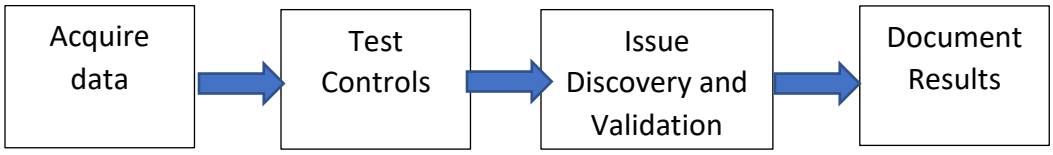
– The project will lead to a report that is objective and will not mislead the reader

Each phase in the audit process is subsequently divided into key steps to plan, define, perform and report the results of the engagement in line with audit standards as in the diagram below.

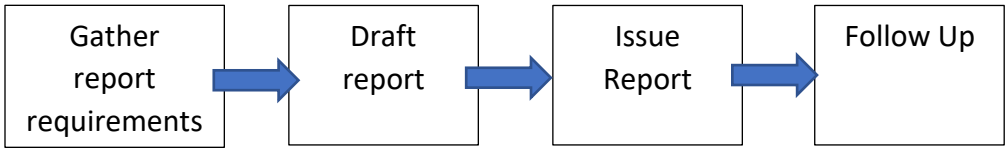
Planning Phase



Fieldwork and Documentation Phase



Reporting Phase



The organization and naming convention for the steps described in this guide can be customized to meet enterprise needs as long as the procedures and outcomes comply with applicable audit standards and meet the intended goal for the audit engagement.

The steps shown above can be further broken down into more specific activities. The table below describes the typical activities that will be performed during each step in the planning phase.

Planning Phase

	Audit Step	Description
1	Determine audit subject	Identify the area to be audited (e.g., business function, system, physical location)
2	Define audit objective.	Identify the purpose of the audit. For example, an objective might be to determine whether program source code changes occur in a well-defined and controlled environment
3	Set audit scope.	Identify the specific systems, function or unit of the organization to be included in the review. For example, in the previous example (program changes), the scope statement might limit the review to a single application, system or a limited period of time. This step is very important because the IS auditor will need to understand the IT environment and its components to identify the resources that will be required to conduct a comprehensive evaluation. A clear scope will help the IS auditor define a set of testing points that is relevant to the audit and further determine the technical skills and resources necessary to evaluate different technologies and their components.
4	Perform preaudit planning.	• Conduct a risk assessment, which is critical in setting the final scope of a risk-based audit. For other types of audits (e.g., compliance), conducting a risk assessment is a good practice because the results can help the IS audit team to justify the engagement and further refine the scope and preplanning focus. • Interview the auditee to inquire about activities or areas of concern that should be included in the scope of the engagement. • Identify regulatory compliance requirements. • Once the subject, objective and scope are defined, the audit team can identify the resources that will be needed to perform the audit work. Some of the resources that need to be defined follow: – Technical skills and resources needed – Budget and effort needed to complete the engagement – Locations or facilities to be audited – Roles and responsibilities among the audit team – Time frame for the various stages of the audit – Sources of information for test or review, such as functional flowcharts, policies, standards, procedures and prior audit work papers – Points of contact for administrative and logistics arrangements

		– A communication plan that describes to whom to communicate, when, how often and for what purposes
5	Determine audit procedures and steps for data gathering.	At this stage of the audit process, the audit team should have enough information to identify and select the audit approach or strategy and start developing the audit program. Some of the specific activities in this step are: • Identify and obtain departmental policies, standards and guidelines for review. • Identify any regulatory compliance requirements. • Identify a list of individuals to interview. • Identify methods (including tools) to perform the evaluation. • Develop audit tools and methodology to test and verify controls. • Develop test scripts. • Identify criteria for evaluating the test. • Define a methodology to evaluate that the test and its results are accurate (and repeatable if necessary).

An audit plan should comprise all five steps shown in the planning phase. An audit program is the product of steps one, two, three and five. For the remainder of this publication the term "audit and assurance program" refers to the outcome of the planning phase that deals with the audit approach and procedures.

Fieldwork and Documentation Phase - Performing the Audit

This is the stage when the actual audit is performed by the IS auditor using various tools. This comes after the planning; IT and the business environment stages have been successfully concluded and a go-ahead has been given to start the audit.

The IS auditor would start by making interview appointments with relevant officers, such as the IT director, IT manager, line mangers, data and systems owners. It is advisable or good practice to commence with senior management such as the CEO, IT director, IT Manger, or line managers so that issues relating to IT governance and other major IT issues affecting the enterprise are discussed first. Later the IS auditor can proceed with interviews with operations staff, such ad IT systems managers, systems administrators, network administrators etc.

Armed with well-developed questionnaires and audit tools, the work of an IS auditor should be a lot easier and happy journey throughout all the offices and departments. As the IS auditor makes appointments to interview various mangers and specialists, he should remember that his work is that of an advisor and value-

adding. The IS auditor should not be seen as a police officer or someone who has come to find faults. Immediately the IS auditor is perceived to be taking the policing role, it is likely that the staff would resent his/her presence and might result in receiving limited corporation from the auditees. An assurance from the Is auditor that he is there to value at the commencement of the audit will help provide the required assurance and enable them to open up and fully cooperate. It is important that the auditees receive assurance from the Is auditor that he is there to help them enhance performance of the enterprise. In many instances the auditees will even volunteer more information than required if they have confidence in the IS auditor.

During the audit, the IS auditor will be required to collect evidence supporting responses from the client. Where the client is not able to provide evidence immediately, it is good practice to write down in the questionnaire (just below the questions) the type of evidence you will be collecting later after the interview. This will help the IS auditor to later compile a list of documents to collect. The Is auditor should not rely on others to be reminded of this responsibility. Everyone is busy, and it is unlikely that they will send a reminder notice.

In addition to collecting responses and evidence in documents form, the IS auditor will be required to make date extracts from live or backup system. It is good practice for the IS auditor to extract data from a non-production system where it is not possible to extract data from a live system. Data can be extracted from backup servers or from the recovery site. Sometimes the IS auditor might be required to observe live real-time systems. In his case, the IS auditor and the client will have to make sure that the connection to the live system is well tested and will not disturb or corrupt the live system. The IS auditor should also request for appropriate authorization from senior management before extracting data from the live system.

In cases where authorization is not given by senior Management, the IS auditor may have to rely on historical data from backup servers. It is also recommended that only suitable and approved software is used to interrogate or connect to live servers.

There are various data interrogation tools on the market which can be used to support different types of audits. The Is auditor can find on the market special software tools which are used to extract data from network devices such as firewalls, routers, switches, and intrusion detection systems. Software houses have also developed specialized software which can be used to extract and interrogate data from different databases such as MS SQL, IBM DB2, Oracle, and MySQL.

An IS auditor will also come across dedicated tools which are used to extract data from applications systems such as financial or ERP systems. There are free open-source and commercial versions available in the market. Data can also be extracted from audit trails or other systems that record user activities on application

servers or network operating systems. Common data extract and analysis tools on the market include ACL, IDEA and Excel. There are also many non-commercial software that can be used.

The purpose of audit software interrogation tools is to extract data so that it can be analyzed and investigated for input and processing errors, data integrity, fraud, and data corruption among many others reasons. Often IT controls nay not be able to identify these errors, and there is a need to use such software as validation tools.

Data stored on servers and data silos hold a lot of information and can tell a lot of hidden stories if properly interrogated. It is also the role of the IS auditor to drill down into these silos and advise management on how business activities are carried out in the enterprise and whether there are significant issues which need management's attention.

Most applications and operating systems have inbuilt tools which flag off errors and other unauthorized activities in addition to the use of audit trail tools. It is almost unforgiveable in any modern enterprise today to implement an ERP system which does not have an audit trail unless other measures have been put in place to gather similar data or perform the same function.

Testing and Evaluation

Once the Audit has been completed through structured interviews, use of questionnaires, observation, walkthroughs, and collection of necessary evidence to support management attestation, the next activity would be to test the information and evidence collected. Before the testing is performed, it is important that the IS auditor reviews the documents and evidence checklist to ensure that all the necessary information has been collected.

Testing involves validating the responses and evidence the IS auditor collected during the audit. Compliance testing is the easiest as it involves confirming whether the enterprise is compliant with various IT policies, procedures, regulations, and laws. The process involves comparing what is expected and what is obtained on the ground. Where the enterprise is not compliant, the auditor will take up the issue for discussion with Mangement and possible inclusion in the final report.

Other tests may involve assessing whether performance standards are being achieved by the enterprise. Performance standards may relate to service levels, maintenance, and monitoring.

Testing may include system testing to ensure that configurations have been implemented according to approved standards. An example would be checking that a firewall configuration was implemented according to accepted standard. Testing a firewall may include conducting a penetration test. An auditor

may also check that a database system was configured with required security hardening standard. Testing systems is more demanding and might take up most of the auditor's time.

The IS auditor may also test whether Its systems are being monitored by IT management. This would involve asking the IT department to show records indicating which system were monitored, what their findings were, and what was reported to Management. Normally, IT departments would have in place monitoring procedures for various systems which indicate what is being monitored and how often the monitoring is being done and what type of data is being collected during monitoring.

During testing, the Is auditor will also be looking for evidence that backups are being carried out and signed off by a senior supervisor. It is normally not safe and sufficient to assume that backups are being carried out through word of mouth. The backup operator should record in a logbook or other system that backups are being taken and reviewed by a senior supervisor or manager. The auditor will also be looking for evidence that the backups are tested for restoration. It is pointless to make backups which cannot be restored.

Access controls also need to be tested in order to ensure that all users have appropriate access rights on the system they are using. User accounts are created and removed every time, and access rights also change due to changing job requirements. Testing that access controls are implemented correctly is one of the regular tasks of an IS auditor.

The Is auditor would take special interest in auditing change management. Change controls also need to be regularly tested in order to ensure that all changes are properly implemented and documented. It is common to find that changes are not documented or tested before being implemented.

Findings and Reporting

The next activity for the auditor after performing the audit and evaluation of findings is to write up a report to Mangement. The report should address the audit objectives outlined in the engagement letter or audit request memo in case of internal IS auditors.

It is always advisable that the audit report is prepared in good time and sent to the client on the agreed dates. Where this is not possible, communication should be sent in good time, indicating that the report will not be ready on the agreed date and reasons given on why the report will be delayed. It is always good to avoid the report being rejected on the basis that it is late, by communicating with the client if there are challenges regarding the preparation of the report.

The Is auditor and the client would have agreed on distribution of the report prior to communicating the audit and most likely during the entry meeting. It is important to adhere to the agreed distribution so that

the report is not sent to unauthorized persons. This is especially more important if the report is going to the board as the report might contain sensitive issues.

One of the controversial issues in most audit meetings is concerning the report format. In some enterprises, preference is given to detailed reports while others accept brief reports. Normally, higher level mangers prefer less-detailed reports than lower operational or technical levels. It is also important to take note of report formats used in the enterprise. It is good practice to follow the clients report format if it does not pose any significant challenges.

The IS auditor should also be aware of organizational politics at various levels. Reports are sometimes rejected because some officers have personal differences or because one of the senior officers did not agree to the terms of reference or audit objectives.

It is accepted practice to report on what has not been achieved or complied with. In some enterprises, management might demand for more information, which includes the entire picture of the IT the environment. This is a requirement which should also be agreed before commencement of the audit, whether report should focus on excerpts only or provide the whole picture.

The Is auditor should take note of the importance of using balanced language in the report. If the recipients are not very technical, it is good practice to use non-technical language unless it is not possible to avoid use of technical words. Where the recipients are technical, it is recommended to use technical language so that the client is able to provide appropriate technical responses to the IS auditors. Where the auditor would like to support the observations and recommendations made with detailed technical data (such as diagrams, specifications, and maps), it is advisable to move such detailed information to the appendix.

Below is a possible report structure which could be used to prepare an audit report.

Report Structure

- Observations
- Risks
- Impact rating
- Recommendations
- Benefits
- Management response
- Responsibility
- Target Data

There are different types of report structures, some that may be specific to particular enterprises. In some enterprises, especially those with an international presence prefer to have uniform reporting tools across all their offices.

Observations: - The auditor should use the column to indicate what he has observed relating to a particular activity. The statement should be made as an observation because the auditor is basing the statement on available information at the time of the audit. The observation should be detailed enough, and where necessary, supported by evidence collected during the audit. If the supporting evidence documentation is large, the IS auditor might consider including the evidence in the appendix.

Risk: - Allows the IS auditor to indicate the risk to the enterprise of observation. The IS auditor may include one or more risks identified.

Impact Rating: - The impact rating can be high, moderate, or low. High impact rating may indicate that immediate action should be taken and with an appropriate level of mitigation. It is advisable to include the impact rating so that the client is aware of the level of impact regarding a particular observation.

Recommendation: - The IS auditor should make clear recommendations in order to enable the client to implement them. Often clients will as how the implementation should be carried out if they are not clear with the IS auditor's recommendations.

Benefits: - Benefits indicate what rewards would be derived from implementing the recommendations. It is important to add benefits in the report as it motivates the client to appreciate the importance of your work.

Management Response: - This is the response management gives on the IS auditors observations. Management might agree or disagree with the observations and recommendations made by the IS auditor.

Responsibility: - This indicates who is responsible for implementing the recommendations made by the auditors. This could be the system owner, the It director, Finance director or functional head.

Target dates: - It is always important to agree with the client on the dates for resolution of the issues raised in the report. This will allow the auditor to follow up on or after the indicated dates.

At the end of the audit, the Is auditor would have collected a number of documents and also generated new ones. Listed below are the various documents and pieces of information the IS auditor would have collected during the audit.

a) Audit charter or IT audit charter
b) Engagement letter or audit request memo
c) Business and IT strategy documents
d) Business process documents
e) IT policies, processes, procedures, and standards
f) Audit questionnaires with collected data
g) Evidence in form of data extracts

h) Evidence in form of compliance documents
i) Data on tests carried out
j) Completed audit report to management

AUDITING IT RISK MANAGEMENT

The IS auditor is required to have a good understanding of IT risk in the enterprise. The IS auditor is also regularly required to carry out IT risk audits because of the nature of IT risk. Many enterprises are dependent on IT to run and manage business operations, and it is for this reason that management requires assurance that IT systems are able to deliver required services and ensure that data and information is protected. IT should also add value to the enterprise in terms of growth, efficiency and profitability.

Many enterprises have implemented IT risk frameworks in order to effectively mange IT risks beyond just implementing disaster recovery procedures. There are many ways of mitigating risks as will be reviewed later.

The IS auditor should have a good understanding of the enterprise risk policy, the risk standards being used, and IT risk procedures which have been implemented. This information will enable the IS auditor to appreciate how IT risk is being managed in the enterprise.

Objectives of Auditing IT Risk management

IT risk objectives may include:

1. To find out if IT risk management framework exists and has been implemented in the enterprise
2. To determine that the IT risk management framework is included in the enterprise's overall risk management framework
3. Determine which risk standards or best practice are used to implement risk management in the enterprise.
4. Establish that a risk register has been developed and covers all the functions in the enterprise
5. To find out if the enterprise carries out regular risk assessment
6. To find out how identified risks are being mitigated and how residual risk is being treated by management
7. To investigate how risks and impact are being analyzed in order to determine appropriate risk treatment
8. To determine how operational staff comply with various risk and operational procedures in order to ensure that risk is properly managed.

IT Risk Governance

The board and senior management should set the tone as to how risk will be managed in the enterprise and indicate what their risk appetite is in terms of what risks they can treat or accept as untreatable risk.

IT risk governance focuses on how the board and senior management handle IT risks in the enterprise. The Is auditor should first find out if the board does understand the risks the enterprise is facing. This can be done by interviewing board members and also reviewing records of board meetings. It is possible that views from the board members may differ for various reasons, but it is generally expected that the board and management will speak with one voice.

The board will set guidance through setting risks strategies, and management will operationalize the framework through implementation of policies and procedures. In order to ensure that risk strategies are being implemented as desired by the formal reports or briefings during board meetings. Senior management also should receive feedback from middle management on IT risk compliance.

In order to have effective monitoring of risks in the enterprise, management should ensure that IT risk audits are performed and reported to the board and senior management. It is recommended that independent IS auditors may discover issues or the risk management team when performing self-assessments.

Risk Management Committee

The board or senior management are normally busy people and do delegate the risk management responsibilities to a team of risk specialists and senior line managers or directors to handle the day-to-day management of risks. In some enterprises, the responsibility can be delegated to a committee with representation from various departments and supported by a risk management function headed by a director or manager.

The purpose of the risk management committee is to coordinate risk management activities in the enterprise, and they are also responsible for monitoring risks and ensure that new or changing risks are quickly identified and mitigated. The risk management committee will also give regular feedback to the board and senior management on risks in the enterprise.

It is recommended that representation on the risk management committee should be across the enterprise in order to ensure that all risk issues are picked up by the committee and reported to senior management and board. The risk management function or department will conduct most of the routine work on behalf of the committee.

The risk management committee should always be available to handle new risks or change in risk exposure. Enterprises will always face different types of risks as they interact with clients, suppliers, regulators, and other enterprises. The IS auditor might look for evidence of availability of the committee members by checking who is on the committee, if they can easily contact by phone or email, and how often they interact with business operations to be able to identify and observe operations and how IT risk procedures are being implemented.

The IS auditor should hold interviews with the board, senior management, and the risk management committee in order to obtain an understanding of their appreciation of the enterprise's risk policy
And procedures. A key consideration is how the board, senior management, and the risk management team monitor IT risk. It is possible that a risk management function could be available but without tools for monitoring risks. Enterprises are dynamic and face various problems which might cause new risks.

The risk management committee should have a risk management program, which is implemented to deal with various risks. The program should include activities such as general IT risk assessment, IT project risk assessments, IT risk monitoring, It risk profiling, change management, IT risk audits, and risk mitigation. The risk management function should consider developing a calendar of activities on how they shall conduct various risk activities.

The risk management committee should meet regularly to discuss business operations and review how risks are being managed. Ad hoc meetings with users can be helpful as a way of monitoring risks. Front desk employees interact with clients and often come across information on what clients think of the enterprise and what the enterprise is doing and not doing.
The risk management committee will also be responsible for performing risk assessments. They are required to perform risk assessments at required times and when new IT projects are initiated or major changes are being made to existing systems.

Change management controls are usually implemented when changes are being made to systems. The objective being that changes should be properly managed to enable rollback in the event that implementation goes wrong. The IS auditor will check if change management is being implemented by checking documentation on change controls, such as testing and approval of changes before they are deployed into production.

Implementing new projects or major changes or upgrades to existing systems mean that new risks might be introduced in the enterprise -e.g a new system that has been implemented may not have a system for alerting customers to pay their subscriptions. If the enterprise goes ahead to implement such a system, it might lose out on revenue as some clients may not pay in time or wait until their subscriptions expire.

Risk management frameworks

There are many standards that are used to implement risk management. In some enterprises, they implement their own internally developed standards, which are usually a mix of various international standards.

ISO 31000 is one of the risk management standards which have been used to implement risk management in many enterprises. The standard is general purpose and can be used by any organization and in any sector. The standard provides a process for managing risks and helps in the improvement of identifying risks, threats and how to treat risks.

ISO/IEC 27005 is an information security standard which is deliberately risk-aligned in order to address many security risks. The standard provides guidelines for information security risk management and is based on ISO/IEC 27001, which is an information security management standard

COBIT 5 for risk has been developed to assist with the effective management of IT risk. The standard focuses on linking information technology risks with business performance. COBIT 5 for risk defines It risk as business risk, specifically, the business risk associated with the use, ownership, operation, involvement, influence and adoption of IT within an enterprise.

ISO 22301 provides guidelines on the requirements for a management system to protect against the likelihood of disruptive incidents which might impact the enterprise. The standard is a business continuity management standard which priorities threats to the enterprise,

IT Risk Assessment

IT risk assessment is the process of identifying risks in the IT environment. Enterprises do use various methods of carrying out risk assessments. One way of starting the process of risk assessment is by identifying critical and non-critical assets in the enterprise.

Critical assets are critical to the operations of the enterprise. In terms of IT assets, we can say that in an IT infrastructure, servers and databases running ERP systems are critical since they are used to support the business of the enterprise and also store data and information generated by the enterprise. Other critical

assets would be the internet of the business enterprise is dependent on the use of the same to conduct business. A distance- learning university usually would conduct all its business operations online. Students are able to register and work their way up to graduation by using an end-to end e-learning system. In such a case, students in different countries can enrol and take courses online via the internet. The internet link and associated systems and devices, such as routers and firewalls, can be regarded as critical assets. Distance-learning universities cannot do without these assets and support students efficiently

Another good example is Amazon.com which conducts its business on the internet and cannot do without the internet. The Amazon.com web portal can be said to be a critical asset as it is used as the interface with customers. Customers log in and purchase goods via the web portal. Maintaining a 24/7 internet connection is also critical to the survival of the business.

Data and information in both examples given above are critical assets as their operations depend on the use of information and data generated by the enterprise. Without data and information, the two enterprises cannot communicate with its customers or conduct its business activities.

Non-critical assets are used in the enterprise to support core activities or can be said to be non-essential items. Printers can be said to be non-critical items in the distance-learning university example as the university can do without printers for some time compared to not having internet traffic. Lack of internet connectivity would mean no communication with students; students would also not be able to access documents and their coursework. Other examples of non-critical assets in the distance-learning university would be office productivity software such as Microsoft Word or PowerPoint. Whilst these tools are essential in the office, they are not critical to the operation of the university compared to the student administration and course-delivery system.

Once critical assets have been identified, it is now possible to identify risks related to critical assets. It will not serve the enterprise any good to spend time to identify risks for non-critical assets because the enterprise can do without them for a while without major impact on the operations of the enterprise.

The risks to university distance-learning systems include loss of data through damage to database systems, the web portal not being available because the system has been hacked, theft of data through internal collusion, and system malfunctioning.

Identified risks can be categorized as high, moderate or low risk. High risk assets require high-level attention whilst low-risk assets will require minimal attention, if not none, depending on its impact level. Categorizations of risk enables an enterprise to rate asset risks and determine how much effort should be applied in treating them.

Example

	Asset	**Criticality**	**Risk Rating**	**Cost**
1	ERP System	Critical	High	High
2	Network Equipment	Critical	High	High
3	Data and Information	Critical	High	High
4	Office Application Systems	Non-Critical	Low	Low
5	Messaging System	Critical	High	High
6	Fire Suppression System	Critical	Low	Medium
7	Scanning Software	Non-Critical	Low	Low

In the diagram above, assets 1,2,3,5 and 6 are critical to the operations of the enterprise and have high replacement cost, apart from the fire suppression system, which might have low to medium cost assuming the system is localized to the data center. High value assets are normally high-risk assets.

In order to assess the riskiness of a particular asset, the IS auditor should also identify threats to that asset. Some assets might have high risks but without possible threats. Where there are no threats, it would not be necessary to take particular measures to treat risks. It should be recognized that threats change over time and should be regularly monitored.

Threats take advantage of vulnerabilities in systems. Once threats have been identified, it is also important to know what vulnerabilities exist in the systems. Where there are no threats, it is possible that no action is required to fix vulnerabilities. It might not be worth the while and cost to try to fix vulnerabilities where there are no known threats.

The last part of risk assessment is to assess possible impact on assets in the event threats actually hit the enterprise and disable or destroy assets. High impact would mean devastation of company assets. Measures should be taken to ensure that operations are able to continue after impact either in a limited way or full service. The figure below shows the impact and possible action to be taken by management.

	Risk		Impact	Expected and Action
1	High	Vs	Low	Minimum Action
2	High	Vs	Moderate	Action Required
3	High	Vs	High	Action Required
4	Low	Vs	Low	No Action
5	Low	Vs	Moderate	Action Required
6	Low	Vs	High	Action Required
7	Moderate	Vs	Low	No Action
8	Moderate	Vs	Moderate	Action Required
9	Moderate	Vs	High	Action Required

Impact Matrix

1. High risk vs Low Impact: Although the likelihood of the event happening is high, the impact on the enterprise is low. The enterprise might opt to accept the risk or take minimum or low-cost mitigation measures. An example would be backup data stored in a secure place. While the risk is high that the data can be lost, the impact might be low because copies of the backups are kept in other sites.
2. High risk vs moderate impact – High risk combined with moderate impact requires action to be taken as the possibility of the event is there. Moderate impact might disable operations of the enterprise depending on the criticality of the asset and its value. It is possible that an ERP system might have a high risk because of the nature of the asset and the impact moderate if appropriate controls are applied.
3. High risk vs high impact: High risk assets include data and information. Loss of data can have a high impact as the enterprise would have to recreate the data, and this might mean halting business operations for some time if the enterprise does not have an effective disaster recovery plan.
4. Low risk vs low impact: The enterprise might choose not to do anything and accept the risk if the risk is low and impact is low. The enterprise might be interested in assessing the impact on the enterprise even if the risk is low. There is a possibility that the risk might exist but with low impact that does not look bad. The enterprise might consider low-cost insurance to cover the low impact.
5. Low risk vs moderate impact: A similar analysis and response might be taken in low-risk vs moderate impact situation. Since the impact is moderate and risk low, this means that impact is possible. Action should be taken to protect the assets. The enterprise can opt for low-cost mitigation since the risk is low. Having trained IT staff would be an example of low risk as we expect them to professionally manage an IT infrastructure.

6. Low risks vs high impact: Low risk meant that the probability of an event is low and remotely possible. An example would be an earthquake happening in a non-earthquake zone. The risk is low but the impact is high. Designers of data centers or buildings may not worry very much about buildings being hit by earthquakes as the risk is low. Management would be worried about the high impact -hence need for some action such as low-cost insurance that can be taken in case the data center is hit by an earthquake.
7. Moderate risk vs Low impact: In this scenario, the risk is moderate, which means that the chances of the event happening is possible. Management needs to take some action depending on the value and criticality of the asset. Risk can be reduced by applying measures such as access control which limits access to authorized users only.
8. Moderate risk vs Moderate impact: In this case, management would be more concerned with the moderate impact and its possible cost. Since the risk is moderate, the risk should be investigated further and management should put in place appropriate mitigation. An example would be loss of network equipment due to lightning. The risk might be reduced due to measures taken to protect the equipment, such as using surge protectors. The impact might also be reduced if spare equipment is kept for emergencies.
9. Moderate risk vs high impact: High impact automatically means that action should be taken to protect the asset. Moderate risk also means that chances are there that the event might take place. Secure email systems might have moderate risk, but high impact if the data is stolen or corrupted.

IT Risk Policy and Procedures

An enterprise should have a risk policy or framework so that they are able to implement an effective risk regime. The policy is a guide on how a risk framework will be implemented and managed in the enterprise. It is recommended that a risk policy should be based on accepted best practice or international standard such as ISO 31000, COBIT 5 for risk, ISO 27005 and ISO 22301.

Policy is also a guide to the IS auditing team so that they can have a clear understanding of management intentions and risk appetite. The IS team might in addition, appraise themselves on enterprise risk by reviewing IT risk processes implemented in the enterprise.

The Is auditor should not only read the risk policy, but also verify that the policy is operational. There are various mechanisms which can indicate that the policy is operational, such as risk monitoring systems and procedures.

The format and contents of the risk strategy and policy will defer from one enterprise to the other but would generally contain the following details:

Risk Strategy: The strategy will highlight how the board and management plan to manage risk in the enterprise. This will be expressed as part of the overall enterprise strategy. Risk strategy will also include risk governance

Risk assessment: This is the identification of risks on enterprise assets and systems. Assets here include human assets who are trained and used by the enterprise as productive assets. Risk assessment can be carried out on a particular periodic basis or when new projects are being implemented.
Asset identification: Assets can be categorized as critical and non-critical assets. Management can also rate the risks of various assets.

Risk treatment: When risks are identified and impact assessed, it is possible to recommend an appropriate treatment. The policy will include various ways of treating risks or accepting risks.
Risk register: The register is basically a list of risks which the enterprise is facing based on the nature of its business and how these risks would be mitigated. The risk register would highlight various risks and related information.

<Risk Register-Appendix>

Risk Monitoring: The policy will also indicate how risks in the enterprise will be monitored, including procedures and tools which will be used. Risk monitoring would include regular IS audits by both internal and external auditors.

Risk plan: The policy will also include a risk plan and how it will be implemented. Many large enterprises have fully functioning risk departments which develop and implement the risk plan.

The IS auditor will be required to review the implementation of a risk policy covering all or some of the areas as stipulated in the risk policy. The IS auditor will hold interviews with the board and senior management in order to determine how the policy is being implemented. Other stakeholders will include departmental heads, suppliers and customers.

Enterprises implement and use risk procedures in order to establish controls in business processes. Where business procedures are properly implemented, it is likely that risk exposure will be minimized.

The IS auditor will for example, be required to audit IT procedures, such as creation of user accounts. This procedure may require that a request for creation of new user account is submitted by the line manager and IT manager depending on the structure in the enterprise. The IT department will only create the new account upon completion of the authentication procedures.

IT Project Risk

Enterprises implement various IT projects during a particular period and each project comes with its various risks which have an impact on overall risk profile of an enterprise. Failure of a project might have an impact on the operations of the enterprise.

Projects are initiated to update current systems in part or the whole system. In other cases, projects may be used to completely replace a system. In order to successfully implement a projects, enterprises need to ensure that proper plans are developed for the project.

There are plethora of both private and public enterprises having massive project failures because of poor identification and treatment of risks. The overall risk policy of the enterprise should be a guide as to how risk will be managed in the enterprise. Projects might also have their own specific project risk goals which of course should not be in conflict with the enterprise risk policy.

Various project standards emphasize on the proper management of project risk throughout a project life span. Risks also change during the life of a project due to interaction with other projects, internal resources, and other stakeholders such as suppliers, consultants, external projects team members, and government.

Planning ia a key process when handling project risk as it takes into consideration various factors which might impact the project. One example is the availability of resources, or equipment to be used on the project. Often project mangers do not plan property and encounter problems when the project is being implemented.

Project scope outlines what is to be accomplished on the project. Many projects fail because of poorly defined scope. Changes in scope while the project is being implemented need to be considered with risk

management in mind. Changes to scope can possibly introduce new risks. The project manger should always be mindful of how scope is managed and factors which might lead to changes in scope.

The Project manager should ensure that all changes in scope are subjected to a risk assessment before approval and implementation. The IS auditors' interest is to ensure that risk management procedures are properly implemented during a project so that risks do not negatively impact implementation of a project or operations of the enterprise.

Time management is a critical aspect of projects. If a project goes beyond the planned time for implementation, it is likely that project costs will also go up in terms of human resource costs and other operating costs.

Lack of adherence to quality is another aspect which might cause a project not to achieve its goals as indicated in the project plan. The IS auditor should also review implementation of quality assurance procedures on the project in order to ensure that quality is maintained.

Auditing project risk involves reviewing how the project was implemented and how risk for the project was managed. Potential project risks are identified during planning of the project and closely monitored during project implementation. It is possible that new risks might arise during implementation which might impact the project negatively or positively.

IT Risk Treatment

One risks have been identified, the enterprise may now decide how to treat the identified risks. There are many ways of treating risks, and the board and senior management should guide the enterprise on their appetite for accepting risk.

When considering risk treatment, it is important to look at factors such as risk categorization, threats and vulnerabilities. These factors will help the enterprise to determine what level of treatment to apply on a particular risk. Where threat levels are high, management might consider applying more complex measures in order to protect the enterprise. High risks are common where the enterprise is conducting its business on the internet that may be accessible by hackers whose interest is to steal vital information, ransom etc.

One option the enterprise might consider is to avoid risks by for example ensuring that all IT equipment being purchased is through certified vendors. It is also an important consideration that It staff are also

trained to use and manage the equipment. Lack of trained staff might introduce risk in the enterprise as operation of equipment might not be up to the required standard.

The other way is treating risk is by transferring risk e.g., through insurance. If the enterprise has determined that there is a risk of fire at the data center, management might decide to insure the equipment and software used at the data center. The enterprise can also transfer risk through equipment warranties.

The other measure management can use is by applying appropriate controls, such as implementing a disaster-recovery site.

An enterprise might decide to accept the risk if it is considered that it is less likely to occur and has low impact on the enterprise such as occurrence of cyclone along the equator.

If the cost of treatment is higher than the assets the enterprise is trying to protect, management might also accept the risk and damage to equipment even if this means going out of business.

IT Risk Register

An enterprise will normally have a risk register which is used to record all risks identified in the enterprise. Each identified risk would include information such as risk rating, probability, threats, vulnerabilities, impact, risk, risk treatment, and risk owners. Enterprises are free to decide on the content of their risk register depending on their risk exposure.

The risk register will include a clear description of identified risks and linked to risk procedures. A link to risk procedure is helpful as it indicates what processes that particular risk is related to. It is possible that the enterprise might link business processes to various identified risk procedures and identified risks. A risk register should be updated (by a specialist) often as activities take place in the enterprise.

The risk register should have a risk rating for each risk. The rating can be high, moderate aor low. Ratings will inform management or other users of this information on how to handle the risk.
Criticality of IT assets is also one piece of information when identifying and treating risks. Critical IT risks are high-value assets to the enterprise and are likely to have a high-risk rating.

The probability of a risk occurring should be identified and included on the risk register so that the enterprise can plan how to respond to such events.

Potential threats also need to be identified and included on the risk register. The impact on the enterprise is a critical event and requires monitoring regularly. It is also important to identify risk owners – people who are responsible for managing a particular risk.

A risk register is useful tool for IS auditors as it provides the necessary information on the risks the enterprise is facing and how the enterprise is responding to the risk.

*Risk register consists of the documents in the Appendix

IT Risk Management Plan

A risk management plan is a document that an enterprise prepares in order to have an effective risk management response. The plan supports the enterprise's risk governance and strategy. The plan would also outline how the identified risks will be used to assess impact on the enterprise and the response from management.

The risk management plan is an important document that should be available in hard copy or soft copy to all users in the enterprise. The plan may be integrated with the risk register so that links between risks and action plans can be clearly shown.

IT RISK Assessment Plan

Risk assessment plan is an annual plan which includes a risk assessment schedule outlining how often risk assessment should be conducted. A key requirement is the need to have a risk assessment conducted every time new projects are being implemented; they have an impact on the enterprise. Such risk assessments would provide vital information on how the projects would impact the enterprise as a whole and if new projects introduced new risks in the enterprise.

	Audit type	Q1	Q2	Q3	Q4
1	Annual Risk Assessment	Y			
2	Periodic Risk Assessment	Y	Y	Y	Y
3	Project 1	Y			Y
4	Project 2	Y			Y

The diagram above shows for types of risk assessments. The first one is the annual risk assessment which can be conducted at the beginning of the year. The other risk is the periodic risk assessments which can be conducted every quarter and results compared with the annual risk assessment. Every project in the

enterprise should be subjected to risk assessment. Project risk assessment can be conducted at the beginning and at the end of the project. Project assessments may also be conducted more regularly depending in the project requirements.

Auditing a risk management plan and its implementation is essential as it will enable the IS auditor to assess how effective the plan is and how the enterprise is managing IT risk. The Is auditor may also be required to review the results of the annual and periodic assessments in addition to project-specific risk assessment.

INTERNET ACCESS:

Common Internet Access Security Issues:

• Email Viruses

– Using an anti-virus scan software on your PC and keeping it current is important.

– However, virus software cannot catch all potential viruses. More important, do NOT open any email attachment unless you are exactly sure what it is.

• Other Viruses

– Any firewall will block most all of these viruses before they can reach your PC.

• Adware/Spyware

– Spyware or adware is software that gets onto a PC and modifies the behavior of your web browser.

– Precaution: Avoid downloading free software from companies you are not familiar with, or at least be very cautious when doing so.

• Email Hoaxes

– Various email hoaxes continually go around the Internet. Recently, the most common are emails that look like they are coming from ebay, paypal, citibank, etc claiming there is a problem with your account and you need to update or confirm your account info.

– Precaution: Never send any sensitive information such as credit card #, password, or SSN in an email, as no legitimate company will ever request this information via email.

Computer, email and internet usage:

- Company employees are expected to use the Internet responsibly and productively. Internet access is limited to job-related activities only and personal use is not permitted
- Job-related activities include research and educational tasks that may be found via the Internet that would help in an employee's role
- All Internet data that is composed, transmitted and/or received by <company's> computer systems is considered to belong to <company> and is recognized as part of its official data. It is therefore subject to disclosure for legal reasons or to other appropriate third parties
- The equipment, services and technology used to access the Internet are the property of <company> and the company reserves the right to monitor Internet traffic and monitor and access data that is composed, sent or received through its online connections
- Emails sent via the company email system should not contain content that is deemed to be offensive. This includes, though is not restricted to, the use of vulgar or harassing language/images
- All sites and downloads may be monitored and/or blocked by <company> if they are deemed to be harmful and/or not productive to business

• The installation of software such as instant messaging technology is strictly prohibited

Email Security:

• Real-time Spam Detection – Real-time spam protection against zero-day (previously unknown vulnerability) spam attacks that carry the highest threat level during the initial few hours.

• Disclosure of Information: Most emails are currently transmitted in the clear (not encrypted). By means of some available tools, persons other than the designated recipients can read the email contents.

• Traffic analysis: It is believed that some countries are routinely monitoring email messages as part of their surveillance. This is not just for counter-terrorism reasons but also to facilitate combat against industrial espionage (spying) and to carry out political eavesdropping(listening private information).

• Modification of messages: email contents can be modified during transport or storage. Here, the man-inthe-middle attack modify all the email packets going to and from the mail server or gateway.

• Masquerade: It is possible to send a message in the name of another person or organization.

• Replay of previous messages: Previous messages may be resent to other recipients. This may lead to loss, confusion, or damage to the reputation of an individual or organization.

• Spoofing: False messages may be inserted into mail system of another user. It can be accomplished from

within a LAN, or from an external environment.

• Denial of Service: It can put a mail system out of order by overloading it with mail shots.

What to do?

• To provide a reasonable level of privacy, all routers in the email pathway, and all connections between them, must be secured.

• This is done through data encryption, which translates the email's contents into incomprehensible text that, can be decrypted only by the recipient.

Digital Signature:

• A digital signature is a mathematical scheme for demonstrating the authenticity of a digital message or document.

• A valid digital signature gives a recipient reason to believe that the message was created by a known sender, such that the sender cannot deny having sent the message (authentication and non-repudiation) and that the message was not altered in transit (integrity).

- Digital signatures are commonly used for software distribution, financial transactions, and in other cases where it is important to detect forgery or tampering.
- Digital signatures are commonly used for software distribution, financial transactions, and in other cases where it is important to detect forgery or tampering
- A digital signature scheme typically consists of three algorithms:
- A key generation algorithm that selects a private key uniformly at random from a set of possible private keys. The algorithm outputs the private key and a corresponding public key.
- A signing algorithm that, given a message and a private key, produces a signature.
- A signature verifying algorithm that, given a message, public key and a signature, either accepts or rejects the message's claim to authenticity.

Applications of digital signatures:

- Authentication
- Integrity
- Non-Repudiation

BUSINESS CONTINUITY PLANNING (BCP) AND DISASTER RECOVERY PLANNING (DRP)

- Recent events such as terrorist attacks and high-profile disasters together with an increased need for corporate governance have changed the emphasis of Business Continuity and Disaster Recovery Planning away from towards what was predominantly Information Technology (IT) recovery.
- Detailed plans are created that clearly outline the actions that an organization or particular members of an organization will take to help recover/restore any of its critical operations that may have been either completely or partially interrupted during or after (occurring within a specified period of time) a disaster or other extended disruption in accessibility to operational functions.

BCP:

- Business Continuity Planning is best described as the processes and procedures that are carried out by an organization to ensure that essential business functions continue to operate during and after a disaster.
- By having a BCP, organization ‘s seeks to protect their mission critical services and give themselves their best chance of survival.
- This type of planning enables them to re-establish services to a fully functional level as quickly and smoothly as possible.
- BCPs generally cover most or all of an organization's critical business processes and operations.

DRP:

- Disaster Recovery Plan (DRP) - As part of the business continuity process an organization will normally develop a series of DRPs.
- These are more technical plans that are developed for specific groups within an organization to allow them to recover a particular business application. E.g. Information Technology (IT) DRP.
- The typical test for a DR Plan for IT would be; "if we lost our IT services how would recover them?"
- IT DR plans only deliver technology services to the desk of employees. It is then up to the business units to have plans for the subsequent functions.
- ***Business Continuity Planning***
    - It is the way an organization can prepare for and aid in disaster recovery.
    - It is an arrangement agreed upon in advance by management and key personnel of the steps that will be taken to help the organization recover should any type of disaster occur.
    - These programs prepare for multiple problems.

• ***Disaster Recovery (DR)***

- It is the process an organization uses to recover access to their software, data, and/or hardware that are needed to resume the performance of normal, critical business functions after the event of either a natural disaster or a disaster caused by humans.
- Disaster Recovery plans, or DRPs, often focus on bridging the gap where data, software, or hardware have been damaged or lost, one cannot forget the vital element of manpower that composes much of any organization.
- A building fire might predominantly affect vital data storage; whereas an epidemic illness is more likely to have an affect on staffing.
- Both types of disaster need to be considered when creating a DR Plan.
- Thus, organizations should include in their DRPs contingencies for how they will cope with the sudden and/or unexpected loss of key personnel as well as how to recover their data.

Security Organization Structure:

To follow and maintain security of organization it is necessary to define roles and responsibilities among the staff as well as maintain flow of information. Figure below shows how should be the security organization structure.

IT GOVERNANCE

"The act, manner or function of governing."

- IT governance is defined as 'establishing chains of responsibility, authority, and communication to empower people. 'The key concepts of this definition are found in the mnemonic ―RACE':
- Responsibility – being held accountable for a specific duty, task, or decision
- Authority – the power to influence behavior
- Communication – exchanging information
- Empowering – giving official authority to act

What is IT Governance?

- IT governance (ITG) is defined as the processes that ensure the effective and efficient use of IT in enabling an organization to achieve its goals.
- "IT governance is the responsibility of the board of directors and executive management. It is an integral part of enterprise governance and consists of the leadership and organizational structures and processes that ensure that the organization 's IT sustains and extends the organization's strategies and objectives."
- Accountability (Responsibility) of IT
- IT compliance to rules and regulations
- Satisfying the needs of the board and stakeholders
- Manage IT Risk
- Provide value to the business and control of work done

Decisions are at the core of governance, as

- Which decisions are to be made;
- Where decision will be opened and closed;
- How decisions are reached; and
- Who will be accountable for results

Structure defines the composition of the bodies that make or execute on joint decisions.

Relationship Management informs how parties work together

Objectives of ITG

- Enable the strategic alignment of IT with organization 's priorities and goals.
- Understand the value and impact of IT investments (human resources and capital)
- Identify opportunities for improved IT utilization.

- Support visible and transparent decision making.
- Establish and sustain effective IT policies.
- Establish performance measurements.
- Identify and mitigate (reduce) risks.
- Satisfy regulatory and formal compliance requirements

	Dimension	Definition
INPUT	IT Compliance Management	Assurance that IT meets legal, regulatory and policy requirements. Deviations are analyzed and deficiencies are managed
	IT Risk Management	Formal process of identifying and identifying risks and as well as treating them reasonably in accordance to the organizations risk appetite
	IT Decision Authority and Responsibility	Organizational structure roles and authority for decision making and connected responsibilities
	IT Performance and quality Management	Valid measurement and monitoring of IT performance and solution quality in accordance with business requirements
	IT Investment Management	Ensuring consistent management of IT priorities and minimal IT investment misguidance
	IT Resource and Capability Management	Oversight of the allocation of IT resources, routines and operations that enable value delivery
	IT Governance Improvement	Structures, activities and relational mechanisms by which the IT governance capabilities dynamically evolve and improve.
OUTPUT	Business/IT Alignment	Process of balancing IT with business strategies and functions
	Business Value Delivery	Contribution to and realization of business value by IT

Dimensions of IT Governance

<u>Good It Governance</u>

- Good governance is an indeterminate term used in international development literature to describe how public institutions conduct public affairs and manage public resources.
- Governance is "the process of decision-making and the process by which decisions are implemented (or not implemented".
- The term governance can apply to corporate, international, national, local governance or to the interactions between other sectors of society.

- The concept of ―good governance‖ centers around the responsibility of governments and governing bodies to meet the needs of the masses as opposed to select groups in society.

Characteristics of good IT governance

- Accountability is a fundamental requirement of good governance.
- Local government has a responsibility to report, explain and be answerable for the consequences of decisions it has made on behalf of the community it represents.

- Good governance is transparent
  - People should be able to follow and understand the decision-making process.
  - This means that they will be able to clearly see how and why a decision was made – what
  - information, advice and consultation council considered, and which legislative requirements followed.

• Consensus Oriented

Good governance requires consultation to understand the different interests.

• Good governance follows the rule of law

– This means that decisions are consistent with relevant legislation or common law and are within the powers of council (committee).

• Good governance is responsive

– Local government should always try to serve the needs of the entire community while balancing competing interests in a timely, appropriate and responsive manner.

• Good governance is equitable and inclusive

– A community‘s wellbeing results from all of its members feeling their interests have been considered by council in the decision-making process.
– This means that all groups, particularly the most vulnerable, should have opportunities to participate in the process.

• Good governance is effective and efficient

– Local government should implement decisions and follow processes that make the best use of the available people, resources and time to ensure the best possible results for their community.

• Good governance is participatory

• Anyone affected by or interested in a decision should have the opportunity to participate in the process for making that decision.

• This can happen in several ways – community members may be provided with information,

asked for their opinion, given the opportunity to make recommendations or, in some cases, be part of the actual decision-making process.

Appendix

Likelihood Scale

Rating	Subjective Criteria	Objective Criteria
1	Unlikely	If an incident occurs once in an academic/financial year
2	Likely	If an incident occurs once in a semester/quarter
3	Almost Certain	If an incident occurs once in a month

Consequence Scale

Rating	Descriptor	Legal	Financial	Reputational	Contractual	Operational
1	**Low**	Legal issues leading caution/warnings	Losses of upto Kshs. 500,000.00	Negative reputation about the University internally	Contractual issues that can be resolved internally	Disruption of operations for upto one day
2	**Medium**	Legal issues leading to sanctions	Losses of between Kshs. 500,001 upto Kshs. 4,000,000.00	Negative reputation about the University among the Stakeholders	Contractual issues that can be resolved through arbitration	Disruption of operations for upto one week
3	**High**	Legal issues leading litigation	Losses >Kshs. 4,000,000.00	Negative reputation about the University on the Media (press/social media) or the general public	Contractual issues that can be resolved through litigation	Disruption of operations for more than one week

Risk Appetite

Likelihood

	1	**2**	**3**
1	1	2	3
2	2	4	6
3	3	6	9

Consequence

KEY:

	Low risk level - no further action required. Only monitoring of existing controls at departmental level (Accept and Monitor)
	Medium risk level - Further action required and escalation to the MR (Reduce)
	High Risk level - Further action required and escalation to the University Management (Reduce)

RISK ASSESSMENT – IT Dept

	Asset	RISK DESCRIPTION	(CAUSES)	Likelihood	CONSEQUENCE (AREA OF IMPACT)					RISK LEVEL	STRATEGY	RISK OWNER
					Legal	Reputational	Financial	Contractual	Operational			
1	Network	Network Breakdown	Power failure	1		2			1	2	Accept and Monitor	IT Manager
			Software and hardware failure	2		2			1	4	Reduce	
			Human error (routing problems, misconfigurations)	2		2			1	4	Reduce	
			Security breach	1		2			1	2	Accept and Monitor	
2	Equipment	Breakdown of computer equipment	Power surge	2		2	1		1	4	Reduce	IT Manager
			Hardware failure	2		2	1		2	4	Reduce	
			Human error (user challenges, misconfigurations)	2		2	1		1	4	Reduce	
			Inadequate endpoint security (antivirus and antimalware)	2		2	1		1	4	Reduce	
3	Website	Customer dissatisfaction	Delay in updating website content	2		2				4	Reduce	IT Manager
4	Software	Developing of ineffective software	Lack of clear procedure/not following best practices	1		2			2	2	Accept and Monitor	IT Manager
			Poor communication between stakeholders	1		2			2	2	Accept and Monitor	
			Lack of proper planning - poor project management	1		2			2	2	Accept and Monitor	
			Inadequate resources	3		2			2	6	Reduce	

RISK TREATMENT PLAN - IT Dept

S/NO.	ASSET	RISK DESCRIPTION	CAUSES	EXISTING CONTROLS	ADDITIONAL CONTROLS	RESOURCES	RISK OWNER	TARGET DATE	RISK ASSESSMENT						
									Likelihood	Consequence (Area of Impact)					Risk level
										Legal	Reputational	Financial	Contractual	Operational	
1	Network	Network Breakdown	Software and hardware failure	Availability of dedicated staff to provide support	1. Additional staff 2. adequate equipment 3. Implement the SOP for Network Administration	1. Human Resource 2. Stationery 3. Hardware 4. Software	IT Manager	30-Dec-23	2		2			1	4
2	Network	Network Breakdown	Human error (routing problems, misconfigurations)	Availability of dedicated staff to provide support	1. Staff capacity building to enhance skill set 2. Implement the procedure for Network Administration	1. Human Resource 2. Stationery 3. Hardware 4. Software	IT Manager	30-Dec-23	2		2			1	4
3	Equipment	Breakdown of computer equipment	Power surge	1. Availability of generator 2. Availability of UPS in core sensitive areas	1. additional UPS to complement the existing ones 2. acquisition of Power surge protectors/Voltage Stabilizers for every building 3. Sensitize staff on best practices on equipment management	1. Human Resource 2. Stationery 3. Hardware 4. Software	IT Manager	30-Dec-23	2		2	1		1	4

4	Equipment	Breakdown of computer equipment	Hardware failure	1. Availability of dedicated staff to provide support 2. Implement the equipment maintenance procedure	1. Plan and request for redundant equipment for critical hardware 2. Sign an SLA with equipment vendor for repairs	1. Human Resource 2. Stationery 3. Hardware 4. Software	ICTS Manager	30-Dec-23	2		2	1		2	4
5	Equipment	Breakdown of computer equipment	Human error - user challenges, misconfigurations	Availability of dedicated staff to provide support	1. Staff capacity building to enhance skill set	1. Human Resource 2. Stationery 3. Hardware 4. Software	ICTS Manager	30-Dec-23	2		2	1		1	4
6	Equipment	Breakdown of computer equipment	Inadequate endpoint security - antivirus and antimalware	1. Availability of software security firewall 2. Availability of antivirus in all PCs	1. acquisition of hardware firewall with bandwidth management features 2. procurement of antivirus deployed on the domain server, for management of endpoint terminals (hosts)	1. Human Resource 2. Stationery 3. Hardware 4. Software	ICTS Manager	30-Dec-23	2		2	1		1	4
7	Website	Outdated information	Delay in updating website content	1. Availability of webmaster to upload content 2. Availability of web champions and corporate communication staff to provide content for upload 3. Any HoD can upload content to be uploaded on the website	Develop and implement an SoP on website management with clear timelines	1. Human Resource 2. Stationery 3. Hardware 4. Software	ICTS Manager	30-Dec-23	2		2				4
8	Software	ineffective software	Inadequate resources for development	An SoP on Management of ICT Projects has been established.	Implement the SoP on Management of ICT Projects	1. Human Resource 2. Stationery 3. Hardware 4. Software	ICTS Manager	30-Dec-23	3		2			2	6